

Лекция 5. Обеспечение безопасности ОС Windows

Учебные вопросы:

1. Основы обеспечения безопасности компьютерных систем.
2. Идентификация, аутентификация и авторизация субъектов доступа.
3. Аудит и система безопасности ОС семейства Windows.
4. Защита объектов ОС Windows.

1. Основы обеспечения безопасности компьютерных систем

Операционные системы являются базовым ПО, составляющим основу любой современной ИС. Поэтому обеспечение безопасности компьютерных систем невозможно без обеспечения надлежащего уровня защищенности ОС, которая должна иметь возможность защитить файлы, память и настройки конфигурации от нежелательного просмотра и изменения.



Несмотря на многообразие современных средств защиты информации в различных операционных средах, первоочередными являются организационные меры, на основе которых строятся все защитные механизмы и от которых зависит эффективность их использования.

Первоочередной организационной мерой, обеспечивающей, в том числе, безопасность ОС, является разработка и исполнение политики информационной безопасности (далее – политики безопасности, ПБ) ИС.

Политика безопасности (информации в организации) – совокупность документированных правил, процедур, практических приемов или руководящих принципов в области безопасности информации, которыми руководствуется организация в своей деятельности. Политика ИБ, являясь документом организационного уровня, которая предполагает проведение оценки рисков информационной безопасности ИС и базируется на модели угроз и модели нарушителя.

Модель угроз – документ, содержащий в себе список угроз, которым может быть подвержена та или иная система, входящая в состав ИС. В качестве основы для ее разработки может быть рекомендована модель угроз, предложенная ФСТЭК РФ.

Оценка рисков предполагает определение вероятности реализации угроз с учетом существующих средств защиты информации. Риск представляет собой сочетание вероятности реализации угрозы безопасности и тяжести возможных негативных последствий.

В составе модели угроз следует отдельно выделить модель нарушителя. Разработчик подсистем безопасности ставит себя на место потенциального нарушителя и представляет, какими способами он мог бы попытаться получить доступ к ресурсам ОС.

В Российской Федерации регуляторами в области информационной безопасности выступают Федеральная служба по техническому и экспортному контролю России (ФСТЭК РФ), ФСБ России, Роскомнадзор (в составе Министерства цифрового развития, связи и массовых коммуникаций РФ) и, в особых случаях, Министерство Обороны России.

Базовыми документами для использования в работе с ПО являются:

~ Приказ ФСТЭК России от 31 августа 2010 г. № 489 «Требования о защите информации, содержащейся в информационных системах общего пользования» регламентирует общие требования к мероприятиям по обеспечению защиты информации в ИС общего пользования;

~ Информационное сообщение ФСТЭК России от 18 октября 2016 г. № 240/24/4893 «Об утверждении требований безопасности информации к операционным системам» определяет сферу применения «Требований» как «ОС, используемые в целях обеспечения защиты (не криптографическими методами) информации, содержащей сведения, составляющие государственную тайну, и иной информации ограниченного доступа при ее обработке в ИС (автоматизированных системах управления)». В соответствии с данными Требованиями выделяются 3 типа и 6 классов защиты операционных систем.

Таким образом, всего может быть создано 18 профилей защиты ОС. Профили защиты формулируют функциональные возможности ОС, проблемы безопасности (угрозы, политику и предположения безопасности), цели безопасности, функциональные требования безопасности и требования доверия к безопасности в соответствии с ГОСТ Р ИСО/МЭК 15408 «Информационная технология (ИТ). Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий».

Исходя из этого, например, в ОС общего назначения (типа «А») 4 и 5 классов должны быть реализованы следующие функции безопасности:

- ~ идентификация и аутентификация;
- ~ управление доступом;
- ~ регистрация событий безопасности;
- ~ ограничение программной среды;
- ~ изоляция процессов;

- ~ защита памяти;
- ~ контроль целостности;
- ~ обеспечение надежного функционирования;
- ~ фильтрация сетевого потока.

В среде, в которой функционирует ОС, должны быть реализованы следующие функции безопасности:

- ~ физическая защита;
- ~ доверенная загрузка ОС;
- ~ обеспечение условий безопасного функционирования ОС;
- ~ обеспечение доверенного маршрута;
- ~ обеспечение доверенного канала.

2. Идентификация, аутентификация и авторизация субъектов доступа.

С каждым зарегистрированным в компьютерной системе субъектом (пользователем или процессом, действующим от имени пользователя) связана некоторая информация, однозначно идентифицирующая его. Это может быть число или строка символов, обозначающие данный субъект. Эту информацию называют идентификатором субъекта. Если пользователь имеет идентификатор, зарегистрированный в системе, он считается легальным (законным) пользователем.



Идентификация – это процедура распознавания пользователя по его идентификатору, присвоенному данному пользователю ранее и занесенному в базу данных в момент его регистрации в качестве легального пользователя системы. Эта функция выполняется в первую

очередь, когда пользователь делает попытку войти в сеть. Пользователь сообщает системе по ее запросу свой идентификатор, и система проверяет в своей базе данных его наличие.

Таким образом, идентификация – предоставление пользователем своих логина и пароля (так называемых идентификационных данных) при входе в ИС.

Аутентификация пользователей является важной частью безопасности ИС, наряду с конфиденциальностью и целостностью. Особенно это важно для систем удаленного доступа, которые устанавливают соединения в общедоступной инфраструктуре недоверенных сетей, таких, как Интернет.

Аутентификация – процедура проверки идентификационных данных, предоставленных пользователем при входе в ИС, то есть, фактически, проверка принадлежности пользователю предъявленного им идентификатора или проверка (подтверждение) подлинности пользователя.

Эта проверка позволяет достоверно убедиться, что пользователь (процесс или устройство) является именно тем, кем себя объявляет. При проведении аутентификации проверяющая сторона убеждается в подлинности проверяемой стороны, при этом проверяемая сторона тоже активно участвует в процессе обмена информацией. Обычно пользователь подтверждает свою идентификацию, вводя в систему уникальную, неизвестную другим пользователям информацию о себе (например, пароль или сертификат). Идентификация и аутентификация являются взаимосвязанными процессами распознавания и проверки подлинности субъектов (пользователей). Именно от них зависит последующее решение системы, можно ли разрешить доступ к ресурсам системы конкретному пользователю или процессу. После идентификации и аутентификации субъекта выполняется его авторизация.

В качестве фактора аутентификации может рассматриваться:

- ~ нечто, что знает пользователь (пароль, PIN);
- ~ нечто, чем обладает пользователь (USB-ключ, OTP-токен, смарт карта);
- ~ нечто, что есть часть самого пользователя – биометрические характеристики пользователя: отпечатки пальцев, голос, сетчатка глаза и др.

Парольный способ аутентификации в настоящее время является самым простым, дешевым и популярным несмотря на то, что недостатки этого способа неоднократно упоминались в разных источниках. Слабая парольная политика или вообще ее несоблюдение приводит к возможности подбора или перебора паролей, что позволяет осуществить несанкционированный доступ к информации различного уровня конфиденциальности.

Аппаратные решения в виде USB-ключей, USB ключей с генератором одноразовых паролей, OTP-токенов и смарт-карт. В общем случае пароли хранит или генерирует устройство, что значительно облегчает жизнь пользователю, а также исключает риск подсматривания их злоумышленником. Однако возникает проблема потери или кражи устройства, кроме того, стоимость аппаратных решений существенно выше обычных парольных систем, а их применение в ряде случаев требует дополнительной технической модификации системы (например, установка считывателей смарт-карт).

Биометрия развивается и становится все более востребованной на рынке. Обусловлено это тем, что биометрические устройства запоминают определенные уникальные особенности человека, свойственные только для конкретной личности, например, сетчатка глаза. Следовательно, аутентификация на основе биометрии – это надежный способ доступа в систему. Так же к плюсам можно отнести

удобство для пользователя: не нужно запоминать длинные пароли или носить с собой ключи или смарт-карты.

Однако биометрия имеет ряд недостатков, помимо того, что отличительные особенности человека могут быть скомпрометированы. Возникает вопрос вмешательства в частную жизнь, личные, культурные и религиозные аспекты, так же вопросы гигиены и травмоопасности.

Несмотря на указанные проблемы и недостатки, аутентификация на основе биометрии является перспективным направлением, так как значительно упрощает процесс и дает возможность выполнять сложные задачи. Решением рассматриваемой проблемы является построение *многофакторной аутентификации*. В большинстве случаев для обеспечения без опасного доступа в систему одного проверочного фактора мало, поскольку любой способ аутентификации имеет свои недостатки. Однако, используя преимущества нескольких разных факторов аутентификации в комплексе, можно существенно снизить риски.

Классическими вариантами двухфакторной аутентификации является сочетание аппаратной или биометрической аутентификации с введением пароля или PIN-кода для разблокировки устройства аутентификации (например, смарт карты).

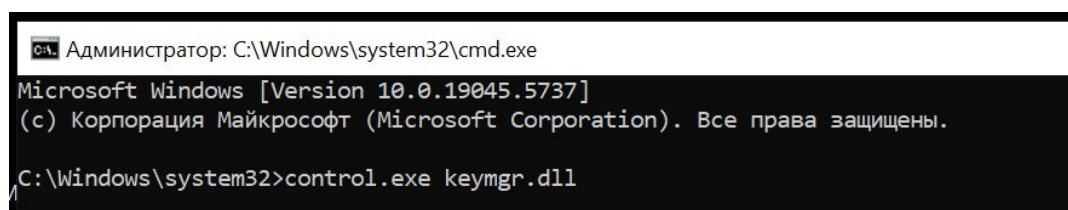
В контексте вышеизложенного можно выделить следующие современные методы аутентификации:

- сочетание пароля и одноразового кода подтверждения, получаемого по SMS на зарегистрированный ранее (доверенный) номер;
- OTP-токен + PIN-код. OTP (One Time Password)-токен – устройство для генерации одноразовых паролей для аутентификации, принадлежащее определенному пользователю;
- QR-код + пароль или PIN-код.

Авторизация – процедура предоставления пользователю (процессу или устройству) определенных прав доступа к ресурсам системы после успешного прохождения им процедуры аутентификации, иными словами, авторизация устанавливает сферу действия пользователя и доступные ему ресурсы. Если система не может надежно отличить авторизованное лицо от неавторизованного, конфиденциальность и целостность информации в этой системе могут быть нарушены.

Авторизация происходит после идентификации и аутентификации.

С процедурами аутентификации и авторизации тесно связана процедура *администрирования действий пользователя*. Задачи аутентификации, авторизации и администрирования тесно связаны между собой. *Администрирование* – это процесс управления доступом пользователей к ресурсам системы. В настоящее время для решения задач идентификации, аутентификации, авторизации и администрирования используют подсистему управления идентификацией и доступом IAM (Identity and Access Management), доступ к которой представлен на рисунке 1.

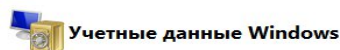
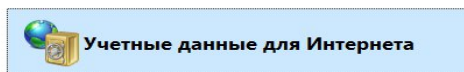


```
Администратор: C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.5737]
(c) Корпорация Майкрософт (Microsoft Corporation). Все права защищены.

C:\Windows\system32>control.exe keymgr.dll
```


Администрирование учетных данных

Просмотр и удаление сохраненных сведений о входе для веб-сайтов, подключенных приложений и сетей.



Веб-пароли

SnapshotEncryptionIV	MicrosoftStore-Installs	⌵
SnapshotEncryptionIV	MicrosoftStore-Installs	⌵
SnapshotEncryptionKey	MicrosoftStore-Installs	⌵
SnapshotEncryptionKey	MicrosoftStore-Installs	⌵

Рисунок 1 - Подсистема управления идентификацией и доступом IAM (Identity and Access Management)

Таким образом, операционную систему называют защищенной, если она предусматривает средства защиты от основных классов угроз. Защищенная операционная система обязательно должна содержать средства разграничения доступа пользователей к своим ресурсам, а также средства проверки подлинности пользователя, начинающего работу с операционной системой.

3. Аудит и система безопасности ОС семейства Windows

Процедура аудита применительно к защищенным ОС заключается в регистрации в специальном журнале, называемом журналом аудита или журналом безопасности, событий, которые могут представлять опасность для системы. Пользователи системы, обладающие правом чтения этого журнала, называются аудиторами.



Аудит необходим по следующим причинам:

~ подсистема защиты компьютерной системы, не обладая интеллектом, неспособна отличить случайные ошибки пользователей от злонамеренных действий. Например, отличить случайную ошибку при вводе пароля от попытки подбора. Но при просмотре журнала администратор сможет установить, что же имело место быть на самом деле;

~ если обнаружено, что против защищаемой системы проведена успешная атака, с помощью журнала аудита можно выяснить, когда и как атака была проведена.

Специалисты по компьютерной безопасности считают, что привилегия работать с подсистемой аудита не должна предоставляться администраторам ОС, что повышает защищенность системы от несанкционированных действий администраторов. При этом отделение аудиторов от администраторов должно быть подкреплено организационно-административными мерами. На практике отделение аудиторов от администраторов практикуется только в крупных организациях (корпорациях, банках и т.п.). При этом обязанности аудитора часто берет на себя должностное лицо, которому непосредственно подчиняются системные администраторы, либо его заместитель.

Подсистема аудита ОС должна удовлетворять следующим требованиям:

~ добавлять записи в журнал аудита могут только псевдопользователи, от имени которых выполняются системные процессы. Если предоставить эту возможность какому-то физическому пользователю, данный пользователь получит возможность компрометировать других пользователей, добавляя в журнал аудита соответствующие записи;

~ ни один субъект доступа, в том числе и сама ОС, не имеет возможности редактировать или удалять отдельные записи в журнале аудита;

~ для ограничения доступа к журналу аудита желательно применять дополнительные средства защиты, например, криптографические;

~ в журнале аудита должны обязательно регистрироваться следующие события: попытки входа/выхода пользователей из системы; попытки изменения списка пользователей; попытки изменения политики безопасности, в том числе и политики аудита.

Окончательный выбор того, какие события должны регистрироваться в журнале аудита, определяется спецификой информации, хранимой и обрабатываемой в ОС. Политику аудита не следует рассматривать как нечто неизменное. Она должна оперативно реагировать на изменения в конфигурации ОС, в характере хранимой и обрабатываемой информации, и, особенно, на выявленные попытки атаковать защищаемую операционную систему.

В некоторых ОС подсистема аудита предусматривает возможность интерактивного оповещения аудиторов о регистрируемых событиях. Данная дополнительная функция позволяет аудиторам более оперативно реагировать на попытки преодоления злоумышленниками защиты ОС и тем самым повышает общую защищенность системы.

В реализацию системы безопасности Windows входят следующие компоненты и базы данных.

Монитор безопасности (Security Reference Monitor, SRM) – компонент, который находится в исполняющей системе Windows (%System Root%\ System32\Ntoskrnl.exe) и отвечает за определение структуры данных маркеров доступа для представления контекста безопасности, выполнение проверки безопасности доступа к объектам,

работу с привилегиями (правами пользователей) и генерацию любых итоговых сообщений проверки безопасности.

Подсистема проверки подлинности локальной системы безопасности (Local Security Authority Subsystem, LSASS) – запускаемый процессом пользовательского режима образ %SystemRoot%\System32\lsass.exe, отвечает за политику безопасности локальной системы, аутентификацию пользователя и отправку сообщений проверки безопасности журналу событий (Event Log).

База данных политики LSASS – содержит настройки политики безопасности локальной системы. Эта база данных хранится в реестре в ACL защищенной области в разделе HKLM\SECURITY (Рисунок 2). Она включает информацию, которая определяет, каким доменам доверена аутентификация попыток входа в систему, у кого есть права на доступ к системе и каким образом осуществляется этот доступ (интерактивные, сетевые или служебные регистрации), кому и какие привилегии назначены и какие виды проверки безопасности следует выполнять. В базе данных политики LSASS также хранятся «секреты», включающие информацию о входе в систему, используемую для кэшированных входов в домены и входов в службы Windows под учетной записью пользователя.

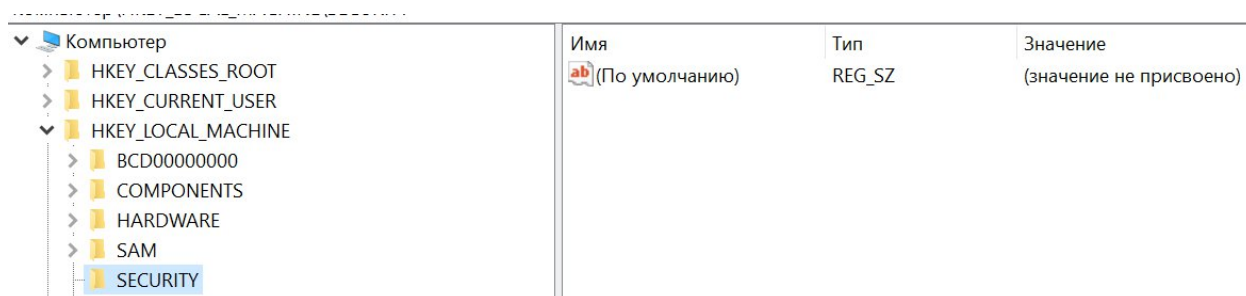


Рис.2 Раздел реестра HKLM\SECURITY

Администратор учетных данных в системе защиты (Security Accounts Manager, SAM) – служба, отвечающая за управление

базой данных, содержащей имена пользователей и определения групп на локальной машине. SAM-служба, реализованная в виде библиотеки %SystemRoot%\System32\ Samsrv.dll, загружается в процесс LSASS.

База данных SAM – содержит определения локальных пользователей и групп наряду с их паролями и другими атрибутами. На контроллерах доменов служба SAM не хранит сведений о пользователях, определенных на домене, но хранит информацию определения учетной записи и пароля системного администратора, имеющего право на восстановление системы.

Эта база данных хранится в реестре в разделе HKLM\SAM (Рисунок 3).

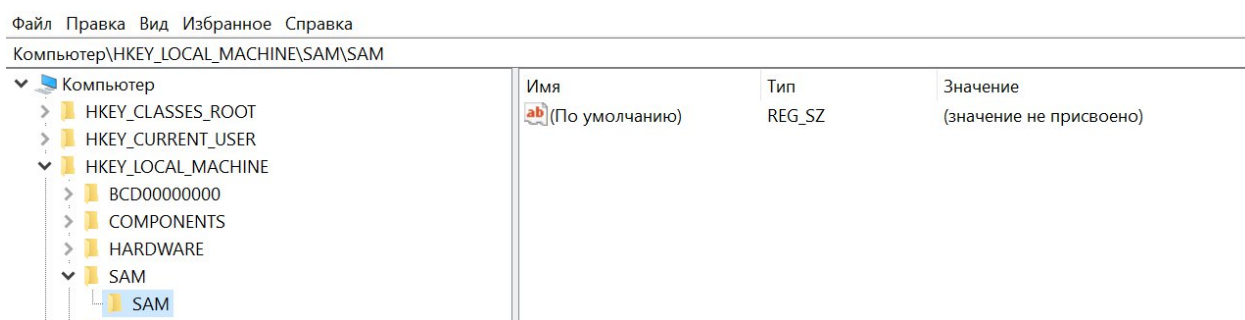


Рис. 3 Раздел реестра HKLM\SAM.

Active Directory – служба каталогов, которая содержит базу данных, хранящую информацию об объектах в домене. Домен является совокупностью компьютеров и связанных с ними группами безопасности, которые управляются как единое целое. Active Directory сохраняет информацию об объектах в домене, куда включаются пользователи, группы и компьютеры.

В Active Directory хранится информация о паролях и привилегиях для пользователей и групп домена, которая тиражируется на компьютерах, назначаемых в качестве контроллеров домена. Сервер Active Directory, реализованный в виде библиотеки %SystemRoot%\System32\Ntdsa.dll, запускается в контексте процесса LSASS.

Пакеты аутентификации (Authentication packages) – включают динамически подключаемые библиотеки – dynamic-link libraries (DLL), которые запускаются как в контексте процесса LSASS, так и в контекстах клиентских процессов и реализуют имеющуюся в Windows политику аутентификации. DLL-библиотека аутентификации отвечает за аутентификацию пользователей, реализуя ее путем проверки соответствия введенного имени пользователя и пароля и возвращения процессу LSASS в случае такого соответствия информации, уточняющей детали пользовательской идентичности с точки зрения безопасности, которые используются LSASS для генерации маркера доступа.

Интерактивный диспетчер входа в систему (Winlogon) – процесс пользовательского режима, в котором выполняется образ %SystemRoot%\System32\Winlogon.exe, отвечающий за реагирование на SAS и за управление интерактивными сеансами входа в систему. К примеру, Winlogon создает первый пользовательский процесс, когда пользователь входит в систему.

Пользовательский интерфейс входа в систему (Logon User Interface (LogonUI) – процесс пользовательского режима, выполняет образ %SystemRoot%\System32\LogonUI.exe, который предоставляет пользователям интерфейс, используемый ими для самоидентификации в системе.

Поставщики учетных данных (Credential Providers, CP) – находящиеся в процессе COM-объекты, запускают процесс LogonUI (стартующий по запросу со стороны Winlogon при выполнении SAS) и используются для получения имени пользователя и пароля, PIN-кода смарт-карты или биометрических данных (например, отпечатка пальца). Стандартными CP являются библиотеки %SystemRoot%\System32\authui.dll и %SystemRoot%\System32\SmartcardCredentialProvider.dll.

Служба входа в сеть (*Network logon service, Netlogon*) – служба Windows (%SystemRoot%\System32\Netlogon.dll), устанавливает безопасный канал к контроллеру домена, по которому отправляются запросы безопасности, например, интерактивный вход в систему (если на контроллере домена запущена Windows NT 4) или проверка аутентификации диспетчера LAN Manager и диспетчера NT LAN Manager (v1 и v2). Netlogon также используется для входов в систему со стороны Active Directory.

Драйвер устройства безопасности ядра (*Kernel Security Device Driver, KSecDD*) – библиотека функций режима ядра, реализует интерфейсы усовершенствованной системы вызова локальных процедур – advanced local procedure call (ALPC), которые используются для обмена данными в пользовательском режиме с LSASS другими компонентами безопасности режима ядра, включая такой компонент, как шифрующая файловая система (Encrypting File System, EFS). KSecDD находится в файле %SystemRoot%\System32\Drivers\Ksecdd.sys.

AppLocker – механизм, позволяющий администраторам определять, какие исполняемые файлы, DLL-библиотеки и сценарии могут использоваться конкретными пользователями и группами. AppLocker состоит из драйвера (%SystemRoot%\System32\Drivers\Appld.sys) и службы (%SystemRoot%\System32\AppldSvc.dll), выполняемой в процессе Svchost.

4. Защита объектов ОС Windows

В число защищаемых в Windows объектов входят файлы, устройства, почтовые ящики, каналы (именованные и безымянные), задания, процессы, потоки, события, ключевые события, пары



событий, мьютексы, семафоры, общие разделы памяти, порты завершения ввода-вывода, LPC-порты, таймеры ожиданий, маркеры доступа, тома, станции окон, рабочие столы, сетевые ресурсы, службы, разделы реестра, принтеры, объекты Active Directory и т. д. – теоретически все, что управляется диспетчером объектов исполняющей системы. На практике те объекты, которые не открыты пользовательскому режиму (например, объекты драйверов), обычно не защищены.

Windows использует единую модель и механизм безопасности, как для файлов в ФС, так и для объектов исполняющей системы.

Проверки прав доступа

Модель безопасности Windows требует, чтобы поток, прежде чем открыть объект, указал, какого типа действия он хочет совершить над объектом. Для выполнения проверок прав доступа, основанных на желаемом потоком доступе, диспетчер объектов вызывает SRM, и, если доступ предоставляется, процессу потока назначается дескриптор, с которым поток (или другие потоки процесса) может выполнять дальнейшие операции над объектом (диспетчер объектов записывает предоставленные права доступа в дескриптор в таблице дескрипторов процесса). На выходе получаем либо «да», либо «нет», что показывает, дает модель безопасности потоку запрошенный доступ или не дает.

Идентификаторы безопасности

Вместо использования имен Windows использует идентификаторы безопасности – Security Identifiers (SID). SID-идентификаторы имеются у пользователей, а также у локальных и доменных групп, у локальных компьютеров, доменов, участников доменных групп и служб. SID представляет собой числовое значение

переменной длины, состоящее из номера версии SID-структуры, 48-разрядного значения идентификатора полномочий и переменного количества 32-разрядных кодов значений подчиненных полномочий или относительных идентификаторов – relative identifier (RID). Значение полномочий идентифицирует агента, выдавшего SID, и этим агентом обычно является локальная система Windows или домен. Значения подчиненных полномочий идентифицируют представителей, имеющих отношение к выдавшему полномочия, а RID-идентификаторы являются просто способом, применяемым в Windows для создания уникальных SID на основе общего базового SID. Из-за большой длины SID-идентификаторов Windows старается сгенерировать внутри каждого SID по-настоящему случайное значение. Практически невозможно, чтобы Windows выдала один и тот же SID на машине или домене, или где-либо еще дважды.

Уровни целостности

Уровни целостности могут заменить разграничение доступа, чтобы провести различия между процессом и объектами, запущенными от имени одного и того же пользователя и находящимися в его владении, предоставляя возможность изоляции кода и данных в рамках учетной записи пользователя.

Механизм мандатного контроля целостности

(Mandatory Integrity Control, MIC) позволяет SRM располагать более подробной информацией о природе вызывающего процесса путем его ассоциации с уровнем целостности. Он также предоставляет информацию о доверии, необходимую для доступа к объекту путем определения для него уровня целостности.

Маркеры

Для идентификации контекста безопасности процесса или потока SRM использует объект под названием маркер (или маркер доступа). Контекст безопасности состоит из информации, описывающей учетную запись, группы и привилегии, связанные с процессом или потоком. Маркеры также включают такую информацию, как ID сеанса, уровень целостности и состояние виртуализации UAC.

Дескрипторы безопасности и управление доступом

Структура данных для информации безопасности, связанной с объектом, которая определяет, кто и какие действия с объектом может выполнять, называется дескриптором безопасности. В дескриптор безопасности входят следующие атрибуты:

- Номер версии. Версия модели безопасности SRM, использованная для создания дескриптора;
- Флаги. Дополнительные модификаторы, определяющие поведение или характеристики дескриптора;
- SID владельца. Идентификатор безопасности владельца;
- SID группы. Идентификатор безопасности основной группы объекта (используется только подсистемой POSIX);
- Избирательный список управления доступом (Discretionary Access Control List, DACL). Указывает, кто и какой доступ имеет к объекту.
- Системный список управления доступом (System Access Control List, SACL). Указывает, какие операции какими пользователями должны регистрироваться в журнале аудита безопасности и конкретный уровень целостности объекта.

Список управления доступом (ACL) состоит из заголовка и нескольких элементов управления доступом (ACE), которых может и не

быть. Существует два типа ACL-списков: DACL и SACL. В DACL в каждом ACE-элементе содержится SID и маска доступа, которая обычно определяет права доступа (чтение, запись, удаление и т. д.), предоставленные или запрещенные держателю SID. Аккумуляция прав доступа, предоставленных отдельными ACE- элементами, формирует набор прав доступа, предоставленных ACL-списком. Если в дескрипторе безопасности отсутствует DACL (то есть имеется нулевой DACL), полный доступ к объекту предоставляется кому угодно. Если DACL пуст (то есть в нем нуль ACE- элементов), никто не имеет доступа к объекту.

Права доступа и привилегии

Для выполнения операций, связанных с безопасностью, различным учетным записям в Windows даются привилегии и права доступа. Привилегии являются правом выполнять под той или иной учетной записью конкретную, связанную с системой операцию, например, выключение компьютера или изменение системного времени. Право учетной записи разрешает или запрещает той учетной записи, которой оно назначено, выполнять конкретный тип входа в систему, например, локальный или интерактивный.

Системный администратор назначает привилегии группам и учетным записям, используя такие инструментальные средства, как MMC-оснастка «Пользователи и группы Active Directory» (Active Directory Users and Groups) – для доменных учетных записей или редактор локальной политики безопасности (Local Security Policy Editor), находящийся в %System Root%\System32\secpol.msc. Доступ к этому редактору можно получить в папке Администрирование (Administrative Tools) Панели управления (Control Panel).

Биометрическая среда для аутентификации пользователей

Windows предоставляет стандартизированный механизм для поддержки определенных типов биометрических устройств, в частности сканеров отпечатка пальца, чтобы обеспечивать идентификацию пользователей: Windows Biometric Framework (WBF).

Кроме особо оговоренных в следующем списке, все эти компоненты

поставляются вместе с Windows:

- Биометрическая служба Windows (Windows Biometric Service, %SystemRoot%\System32\Wbiosrv.dll). Предоставляет среду выполнения процесса, в которой может выполняться один или несколько поставщиков биометрических служб.

- Интерфейс биометрического драйвера Windows (Windows Biometric Driver Interface, WBDI). Это набор интерфейсных определений, которым должен соответствовать любой драйвер для устройства биометрического сканирования, чтобы быть совместимым с биометрической службой Windows.

- Биометрический API Windows (Windows Biometric API). Позволяет существующим компонентам Windows, например, WinLogon и LoginUI, получать доступ к биометрической службе. Приложения сторонних разработчиков имеют доступ к биометрическим API-функциям и могут использовать биометрический сканер для функций, отличающихся от входа в систему Windows. Биометрический API-интерфейс предоставляется библиотекой %SystemRoot%\System32\Winbio.dll.

- Поставщик биометрической службы отпечатков пальцев (Fingerprint Biometric Service Provider). Служит оболочкой для функций биометрических адаптеров того или иного типа с целью присутствия общего интерфейса, независимого от типа биометрии, с биометрической службой Windows Biometric Service.

– Технология Windows Hello, появившаяся в Windows 10, предоставляет новые средства аутентификации пользователей на основании биометрической информации: отпечаток пальца, лицо, сетчатка глаза.

Брандмауэр Windows Firewall

В отличие от сетевых брандмауэров, защищающих периметр, он работает на каждом компьютере под управлением ОС Windows и обеспечивает локальную защиту от сетевых атак, которые сумели обойти периметр сети или были инициированы изнутри. Он также обеспечивает безопасность на уровне отдельных соединений между компьютерами, что позволяет группе безопасности затребовать аутентификацию и защиту данных для всех сеансов связи.

Windows Firewall исследует и фильтрует весь трафик TCP/IP. Входящий трафик отбрасывается, если он не поступил в ответ на запрос со стороны данного компьютера (запрошенный трафик) или не был явно разрешен (не добавлен в список исключений).

Подсистема контроля целостности

В ОС Windows предусмотрена защита системных файлов WRP (Windows Resource Protection) для версий ОС, начиная с Vista, и WFP (Windows File Protection) для старых версий ОС. WRP предотвращает замену основных системных файлов, папок и разделов реестра, установленных как часть ОС. Windows Resource Protection работает, устанавливая дискретные списки доступа (DACLS) и ACL для защищаемых объектов.

Владельцем таких объектов является субъект SYSTEM (Система), а разрешение на чтение-запись допускается лишь процессам, использующим службу, Установщик модулей Windows (Windows Modules Installer –TrustedInstaller.exe).

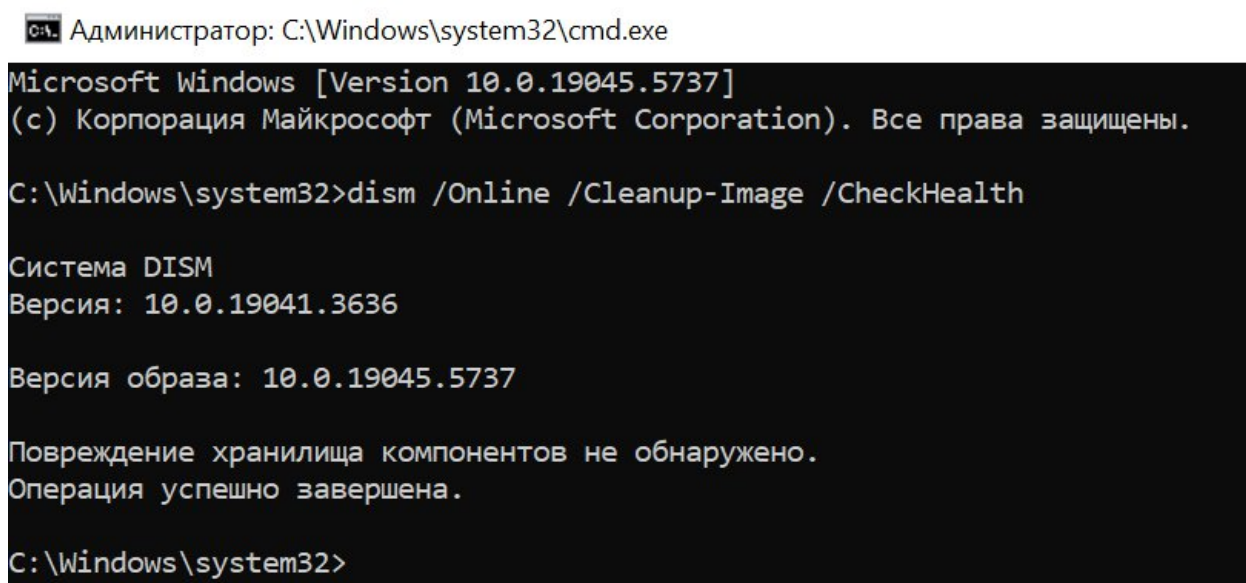
Система защиты ресурсов Windows (WRP) включает два инструмента проверки целостности защищенных системных файлов – SFC (System File Checker) и DISM (Deployment Image Servicing and Management), работающих в режиме командной строки, а также использующую DISM команду Repair-WindowsImage в Windows PowerShell.

Восстановление системных файлов приводит к сбросу некоторых пользовательских настроек (например, замененных значков в Проводнике и пр.), изменения, заданные политиками, не сбрасываются.

Инструмент DISM позволяет выявить и исправить проблемы с хранилищем системных компонентов Windows (начиная с 8). Это может оказаться необходимым в случае, если SFC не может выполнить восстановление системных файлов, несмотря на найденные повреждения.

В командной строке, запущенной от имени администратора, следует выполнить:

- для получения информации о состоянии и наличии повреждений компонентов Windows: `dism /Online /Cleanup-Image /CheckHealth` (Рисунок 4);



```
Администратор: C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.5737]
(c) Корпорация Майкрософт (Microsoft Corporation). Все права защищены.

C:\Windows\system32>dism /Online /Cleanup-Image /CheckHealth

Система DISM
Версия: 10.0.19041.3636

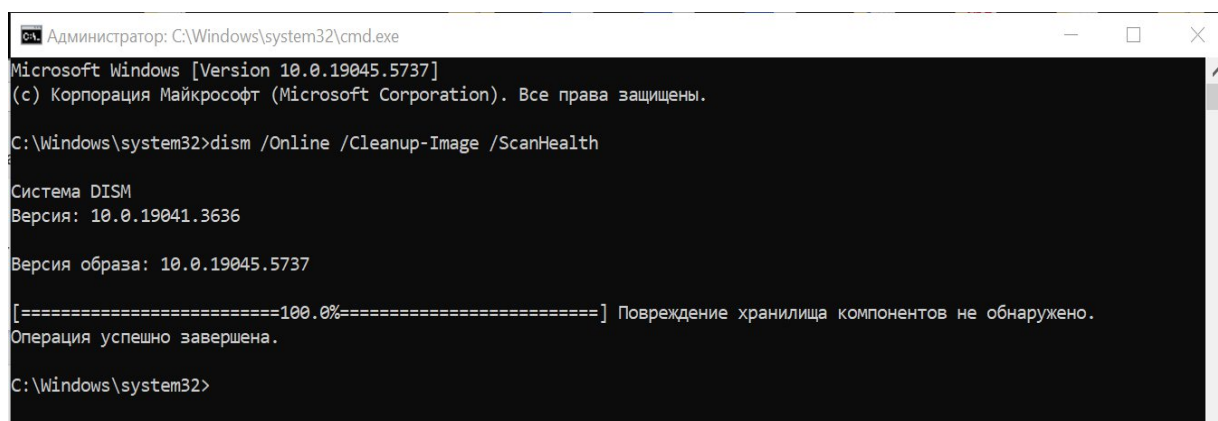
Версия образа: 10.0.19045.5737

Повреждение хранилища компонентов не обнаружено.
Операция успешно завершена.

C:\Windows\system32>
```

Рис.4 Команда CheckHealth

- для проверки целостности и наличия повреждений хранилища компонентов: `dism /Online /Cleanup-Image /ScanHealth` (Рисунок 5);



```
Администратор: C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.5737]
(c) Корпорация Майкрософт (Microsoft Corporation). Все права защищены.

C:\Windows\system32>dism /Online /Cleanup-Image /ScanHealth

Система DISM
Версия: 10.0.19041.3636

Версия образа: 10.0.19045.5737

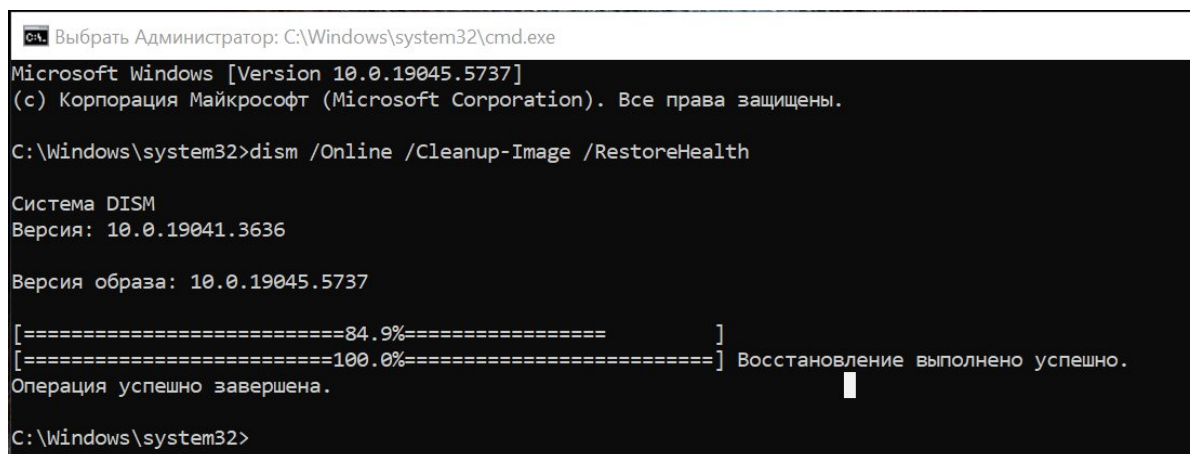
[=====100.0%=====] Повреждение хранилища компонентов не обнаружено.
Операция успешно завершена.

C:\Windows\system32>
```

Рис. 5 Команда ScanHealth

- для проверки и автоматического восстановления системных файлов

Windows: `dism /Online /Cleanup-Image /RestoreHealth` (Рисунок 6).



```
Выбрать Администратор: C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.5737]
(c) Корпорация Майкрософт (Microsoft Corporation). Все права защищены.

C:\Windows\system32>dism /Online /Cleanup-Image /RestoreHealth

Система DISM
Версия: 10.0.19041.3636

Версия образа: 10.0.19045.5737

[=====84.9%=====]
[=====100.0%=====] Восстановление выполнено успешно.
Операция успешно завершена.

C:\Windows\system32>
```

Рис. 6 Команда RestoreHealth

Результаты выполнения команд SFC и DISM протоколируются. Если восстановление системных файлов не удастся выполнить в автоматическом режиме с помощью инструментов SFC и DISM, в файле журнала можно посмотреть, какие конкретно системные объекты были повреждены, а затем восстановить их вручную, скопировав из источника установки (предварительно потребуется сменить владельца файла/ папки и задать соответствующие разрешения доступа).

Защита файловой системы

Главное отличие файловой системы NTFS по сравнению с традиционными файловыми системами – надежность. Во-первых, благодаря восстанавливаемости гарантируется, что структура NTFS-тома не будет повреждена и после системного сбоя доступ ко всем файлам сохранится. Во-вторых, несмотря на отсутствие гарантий сохранения пользовательских данных в случае системного сбоя, приложения могут использовать преимущества сквозной записи и сброса кэша для записи на диск изменений файлов через подходящие интервалы времени.

Функции криптографической защиты

Основным средством криптографической защиты файлов является шифрование EFS, доступное только на томах с ФС NTFS. Поддержка EFS встроена в NTFS-драйвер. При обнаружении зашифрованного файла NTFS выполняет встроенные EFS-функции, осуществляющие шифрование и расшифровывание данных по мере обращения к ним. NTFS отправляет запросы к EFS-службе через подсистему локальной аутентификации (Local Security Authority Subsystem, LSASS).

Для защиты от автономных атак Microsoft предлагает использовать шифрование на уровне тома NTFS с помощью инструмента BitLocker (BitLocker Drive Encryption), доступного в версиях Windows Server, Windows 10 и в более ранних десктопных ОС версий Enterprise и Ultimate. Для съемных носителей (томов с файловой системой, отличной от NTFS) используется технология BitLocker To Go. BitLocker ориентирован, прежде всего, на совместное использование с аппаратным криптографическим процессором - доверенным платформенным модулем TPM и глубоко привязан к конфигурации компьютера.

Шифрование дисков BitLocker может использоваться совместно с шифрованием файловой системы EFS.

BitLocker оставляет незашифрованными:

- заголовок тома (совпадает с заголовком загрузочного сектора);
- поврежденные сектора, если они отмечены как нечитаемые;
- метаданные тома (зашифрованный том содержит три блока метаданных, для обеспечения избыточности).

BitLocker использует фильтрующий драйвер шифрования всего тома (Full-Volume Encryption, FVE), который автоматически видит все запросы к тому на ввод и вывод, зашифровывая блоки при записи и расшифровывая в процессе чтения. В отличие от EFS, функционирующей на уровне файловой системы, BitLocker работает на уровне подсистемы ввода-вывода, находящейся ниже NTFS. Поэтому NTFS «не знает» о включении BitLocker и работает с томом как обычно. Однако при чтении данных с тома при прямом физическом доступе к диску они окажутся зашифрованными. Это касается, в том числе, и системных файлов, если включено шифрование системного тома.

Такая низкоуровневая реализация BitLocker не позволяет задавать для шифрования альтернативные криптографические алгоритмы, в том числе, российские.